

Activité : cryptographie et architecture

Simon Abelard

Janvier 2026

Avertissement : ceci est un exercice créé de toutes pièces à partir d'un cas d'usage réel, cela signifie qu'aucun des choix présentés ici ne reflète l'architecture d'un système existant ou en cours de développement.

1 Contexte

Objectifs :

Élaborer une architecture de sécurité, c'est identifier :

- les composantes d'un système,
- les informations qui transitent entre elles,
- les liens nécessaires pour les faire transiter,
- les besoins de sécurité spécifique à chaque lien,
- les algorithmes cryptographiques permettant de remplir ses besoins,
- (la liste n'est pas exhaustive selon les projets, on peut ajouter : la gestion des clés, les tests, les procédures opérationnelles, la maintenance, etc.)

Description technique :

Nous souhaitons concevoir un système de communications sécurisées par satellite (pensez à la téléphonie ou à l'internet par satellites), composé des éléments suivants :

- Un centre de contrôle (CC)
- Une constellation de satellites (SAT)
- Des antennes permettant au centre de contrôle de communiquer avec les satellites
- Des terminaux utilisateurs (UT) permettant d'échanger des informations avec les satellites

Les informations échangées sont de plusieurs types :

- Échanges internes $CC \longleftrightarrow SAT$: le CC peut envoyer des ordres aux satellites (corriger leur orbite, appliquer des patches logiciels) et, réciproquement, les satellites envoient des informations au CC (acknowledgement, état interne du satellite, etc.)

- Échanges CC $\longleftrightarrow$ terminaux : le CC peut envoyer des mises à jour ou des informations (panne, maintenance) aux terminaux, les terminaux peuvent envoyer des requêtes au CC
- Échanges SAT $\longleftrightarrow$ SAT : les satellites peuvent échanger des informations entre eux (pour relayer des messages ou pour échanger des informations techniques relatives à l'état de la constellation)
- Échanges terminaux $\longleftrightarrow$ terminaux : les terminaux communiquent entre eux (c'est le but du service que fournit le système)

Question 1 : Faire un schéma du système incluant au moins deux satellites et deux terminaux utilisateurs. Avec ce schéma, décrire comment transitent les informations dans les cas listés ci-dessus. En utilisant ce schéma, listez tous les couples possibles de composantes échangeant des informations.

Correction : CC $\longleftrightarrow$ SAT, UT $\longleftrightarrow$ UT, SAT $\longleftrightarrow$ SAT

Question 2 : Mettons-nous un instant à la place de l'attaquant. Analysez comparativement les scénarios suivants en notant de 1 à 3 leur gravité (1= le moins grave, 3=le plus grave) et leur probabilité (1=le moins probable, 3=le plus probable). Pour vous étayer votre analyse, réfléchissez aux conséquences de chaque scénario et à comment il pourrait se produire.

- Un attaquant prend le contrôle d'un satellite
- Un attaquant prend le contrôle d'un terminal
- Un attaquant prend le contrôle du CC

Remarque : en cybersécurité, cette question à rapprocher des notions d'analyse de risque, de cible de sécurité, de threat model et de threat scenario. C'est une tâche complexe conduite par des ingénieurs spécialisés qui suivent des méthodes bien précises (ex : EBIOS).

Correction : Prendre contrôle d'un terminal : 1 en gravité, 3 en proba
Prendre contrôle d'un satellite : 2 en gravité, 2 en proba
Prendre contrôle du CC : 3 en gravité, 1 en proba

Question 2b : Dans un projet bien conduit, l'analyse de risque et la cible de sécurité sont à faire au tout début du projet. Pourquoi ?

Correction : Parce que l'analyse de risque définit le besoin et l'architecture : on définit l'architecture en réaction à des menaces envisagées et à leur impact/probabilité.

2 Sécurisation des liens

Question 3 : On suppose que toute information qui circule dans le système est potentiellement sensible, c'est-à-dire qu'une information que s'échangent deux composantes du système ne doit pas pouvoir être lue par les autres. En reprenant les questions précédentes, expliquer ce que cela implique en termes de clés partagées.

Correction : EN utilisant la cryptographie symétrique, chaque lien doit être sécurisé, donc il faudrait une clé par couple d'interlocuteurs. Ce n'est pas très pratique donc il faut faire en sorte que chaque composante du système puisse négocier des clés (avec un Diffie-Hellman par exemple) avec chaque composante.

Question 4 : On considère plus spécifiquement deux composantes quelconques du système. Quels sont d'après vous les besoins de sécurité entre ces deux composantes ? Quels algorithmes proposeriez-vous ?

Correction : Par exemple entre sol et satellite : on veut confidentialité, intégrité, authenticité. Pourquoi ?

- Authenticité : il faut éviter qu'une personne se fasse passer pour le centre de contrôle
- Confidentialité : protéger les infos/messages échangés
- Intégrité : éviter le rejeu de commandes, par exemple

3 Gestion des clés (key management)

Question 5 : En matière de gestion de clés, les bonnes pratiques sont d'avoir une clé différente par lien et de renouveler régulièrement les clés (on parle de cryptopériode). Expliquez en quoi ces bonnes pratiques améliorent la sécurité, et réfléchissez à quels sont les paramètres qui peuvent influencer le choix de la cryptopériode.

Correction : Il faut minimiser le risque en cas de compromission, d'où l'intérêt d'avoir une clé par usage et de renouveler les clés régulièrement pour limiter l'impact. Un autre aspect c'est que les normes comme celles d'AES-GCM imposent un usage maximal de la clé (taille du fichier et nombre d'appels), même si en général ce n'est pas dimensionnant.

Plus des données sont sensibles plus cryptopériode doit être courte.

Question 6 : Pour renouveler les clés il faut d'abord les générer puis les distribuer. Comment conseillez-vous de procéder pour la génération de clés ?

Correction : Une clé ne peut être générée que de deux manières différentes : soit avec de l'aléa "pur", soit via un processus de dérivation de clés (KDF sécurisée)

Question 7 : Expliquer en quoi la distribution de clés est différente selon qu'on utilise de la cryptographie symétrique ou asymétrique. Insister sur les mesures de protection à mettre en place pour protéger la nouvelle clé que l'on distribue.

Correction : Pour la cryptographie asymétrique, un appareil génère sa propre paire de clés publique/privée avec de l'aléa. Il ne diffuse jamais sa clé secrète et il diffuse sa clé publique (sans la chiffrer, éventuellement en l'authentifiant dans un certificat). Ici on pourrait imaginer qu'un UT demande au CC de signer sa clé publique.

Pour la cryptographie symétrique, la clé secrète doit être partagée à travers un tunnel déjà sécurisé (par exemple après une négociation de clés authentifiée).

Question 8 : Pour la distribution des clés secrètes, donnez votre avis sur les avantages et les inconvénients des méthodes ci-dessous :

- Envoyer la nouvelle clé secrète chiffrée par l'ancienne clé secrète
- Injecter la nouvelle clé secrète dans l'appareil via une connexion physique (par exemple avec une clé USB)

Correction : La première option ne protège pas contre la compromission : si j'ai pu avoir accès à la clé ancienne alors je peux déchiffrer la nouvelle clé et donc j'ai toujours accès au système.

La seconde option est bien plus sûre mais aussi bien plus difficile et coûteuse (il faut payer du personnel pour ça).

Question 9 : D'après vous, peut-on faire mieux pour distribuer les clés secrètes ?

Correction : Négocier ou encapsuler les clés en utilisant la cryptographie asymétrique.

Question 10 : Une menace pour le système est le vol d'équipement cryptographique afin d'en extraire des clés. Pour cela, les équipements intègrent parfois une fonction d'effacement d'urgence qui détruit les clés. Pour chaque composante (CC, SAT, UT), dire s'il est pertinent d'inclure cette fonction et justifier.

Correction : UT : pas la peine car cela coûterait trop cher et n'apporte pas une grande plus-value (un UT compromis n'est pas si grave).

SAT : pas la peine car difficiles d'accès et risque que l'effacement d'urgence soit déclenché par les vibrations lors du lancement.

CC : ici c'est pertinent car on est prêts à mettre le prix, et le vol d'équipement est envisageable (et surtout très grave!)

4 Cryptographie asymétrique

Question 11 : on veut que chaque composante puisse renouveler ses clés à distance. Proposer un mécanisme utilisant la cryptographie asymétrique.

Correction : On effectue un KEX / Diffie-Hellman où les clés publiques sont en réalité des certificats pour assurer l'authenticité. Cela permet de négocier des clés de manière sûre.

Question 12 : Expliquez la différence entre clés statiques et éphémères, en insistant sur l'impact en cas de compromission de clés.

Correction : Si les clés du KEX sont compromises, alors la clé négociée l'est aussi. Si on met la main sur une clé statique on peut donc compromettre un certain nombre de clés négociées.

Avec des clés éphémères, en revanche, on ne compromet qu'une clé au maximum. Et en pratique il est quasiment impossible de retrouver les clés éphémères car celles-ci sont effacées une fois la négociation terminée.

C'est un gros avantage en matière de sécurité qui justifie en général l'utilisation de clés éphémères. L'inconvénient majeur c'est le besoin de recourir à de l'aléa sécurisé à chaque négociation de clé.

Question 13 : Pour chaque composante du système (CC, SAT, UT), dressez la liste de toutes les clés qu'il doit stocker. On suppose que toutes les composantes sont capables de faire de la cryptographie asymétrique et qu'elles utilisent des clés éphémères lorsque c'est possible. Si cela vous aide, vous pouvez vous limiter au cas où il y a deux satellites et deux terminaux.

Correction : Chaque composante doit à minima stocker une paire de clés publique/privée pour la signature, ainsi qu'une paire de clé publique/privée pour l'échange de clés si jamais on choisit une solution statique (dans le cas éphémère, la clé est uniquement générée pendant la négociation).

Chaque composante devra ensuite stocker la clé publique (ou un certificat) de chacun de ses interlocuteurs pour la signature, et éventuellement pour la négociation dans le cas statique. Plus précisément on aura :

- Les UT stockent la clé publique du CC et de tous les UT avec lesquels ils veulent communiquer
- Les SAT stockent la clé publique du CC uniquement
- Le CC stocke les clés publiques de tous les satellites et de tous les CC

Question 14 : Pour chaque fonctionnalité cryptographique, proposer un choix d'algorithme (et éventuellement de paramètres). Vous pouvez vous aider des documents de l'ANSSI https://messervices.cyber.gouv.fr/documents-guides/anssi-guide-mecanismes_crypto-2.04.pdf ou de la NSA

https://en.wikipedia.org/wiki/Commercial_National_Security_Algorithm_Suite

Correction : Un choix possible pour garantir un niveau de sécurité de 128 bits est le suivant :

- Authenticité : signature ML-DSA niveau I ou ECDSA (e.g. courbe NISTp256)
- KEM/KEX : FrodoKEM niveau I ou ECDH (e.g. courbe NISTp256)
- Confidentialité + intégrité : AES-GCM avec clé de 128 bits

Question 15 : Pour chaque composante du système (CC, SAT, UT), dressez la liste de tous les algorithmes cryptographiques qu'il doit pouvoir exécuter. Pourquoi cette question est-elle importante ? Faut-il garder cette liste secrète ?

Correction : On remarque que toutes les composantes doivent connaître tous les algorithmes cryptographiques (à la rigueur on peut choisir des algorithmes différents pour SATs et UTs, mais le CC devra alors savoir faire les deux).

Un exemple de cette liste : AES-GCM avec clé de 128 bits, FrodoKEM au niveau I (équivalent 128 bits), ML-DSA au niveau I.

C'est important car cela dimensionne les modules cryptographiques de toutes les composantes, et cela permet aussi d'estimer les besoins en bande-passante qui dépendent de ces algorithmes (une signature SLH-DSA est environ 10 fois plus grande qu'une signature ML-DSA).

Cette liste n'a pas besoin d'être secrète d'après le principe de Kerckhoff (la sécurité ne repose que sur le fait que la clé soit secrète) mais elle peut être secrète en ce qui concerne le satellite et le CC afin de compliquer le travail d'un attaquant potentiel.

Pour le lien CC $\leftrightarrow$ UC c'est moins utile car un attaquant arrivera sûrement à déterminer ces algorithmes simplement en observant le trafic ou les opérations que fait son appareil.

5 Infrastructure à clés publiques (PKI)

Question 16 : Rappelez (brièvement) le principe d'une attaque de l'homme du milieu (man in the middle). Et expliquez comment s'en prémunir.

Correction : Un attaquant se positionne entre Alice et Bob, envoie une clé publique à Alice en prétendant que c'est celle de Bob et une clé publique à Bob en prétendant que c'est celle d'Alice. Il va alors pouvoir intercepter tout le trafic (et même modifier des messages s'il le souhaite).

Cela vient du fait que les clés publiques ne sont pas authentifiées, il faut donc qu'elle soit signées par un tiers de confiance (une CA), c'est le principe des certificats.

Question 17 : Selon vous, pourquoi serait-il pertinent d'avoir deux PKI différentes pour les clés des UT et des satellites ?

Correction : On imagine qu'il y a beaucoup d'UT (des millions voire des milliards) et moins de satellites (des milliers au maximum). De par la nature des objets, on imagine aussi qu'il y aura des révocations fréquentes chez les UT et beaucoup moins chez les satellites, donc on peut par exemple exclure les CRL des certificats de satellites, avoir des cryptopériodes différentes, une infrastructure plus simple, etc.

Il est donc pertinent d'avoir une PKI séparée, l'augmentation du coût de développement (deux PKI) devrait largement être compensée par les économies dues à la simplification de la PKI des satellites.

Question 18 : Pourquoi pourrait-on envisager une PKI plus simple pour les satellites ? En regardant la norme X509, identifiez quels champs on pourrait supprimer ou simplifier.

Correction : L'essentiel pour un satellite est de savoir identifier la version et les algorithmes employés, à qui appartient un certificat et s'il est valide. Il faut donc à minima indiquer :

- Version number
- Serial number
- Signature algorithm ID
- Subject Public key Info
- Certificate signature algorithm
- Certificate signature

On peut considérer que l'issuer et la CA sont toujours le CC donc pas la peine de le mentionner, on peut aussi supposer que le CC est en charge de gérer l'expiration des certificats donc pas la peine de mentionner de dates de validité, enfin les CRL peuvent être éliminées en considérant que le CC peut juste demander aux satellites d'effacer les certificats compromis.

6 Pour aller plus loin

Question 19 : Pour résister au brouillage, on sécurise les liens $SAT \longleftrightarrow UT$ avec une clé symétrique propre à chaque satellite. Quel impact sur l'architecture de sécurité ?

Correction : Chaque satellite doit avoir sa propre clé symétrique que le CC pourra leur envoyer par liaison sécurisée. Il faut évidemment que le CC transmette la clé aux UT, et que les UT soient capables de savoir quel satellite leur parle (pour pouvoir utiliser la bonne clé). Cela protège la disponibilité du service.

Question 20 : dérivation de clés Entre deux entités, la cryptographie asymétrique permet de négocier une clé de session K_s . Pour en déduire plusieurs clés, on utilise une fonction pour générer plusieurs clés $K_i = KDF(K_s, FixedInfo_i, sel)$.

Justifier l'intérêt d'un tel mécanisme. Quelles sont les propriétés de sécurité que l'on attend pour la fonction KDF ?

Correction : Cela permet de négocier une unique clé de 128 ou 256 bits, au lieu d'en négocier beaucoup plus. C'est un gain de bande-passante et de temps. Evidemment la KDF doit satisfaire les critères suivants :

- Impossible de retrouver K_s , même en connaissant le sel, tous les K_i et tous les $FixedInfo_i$.
- Impossible de retrouver une clé K_j à partir des autres K_i pour $i \neq j$, même en connaissant le sel et tous les $FixedInfo_i$.

Question 21 : séparation de domaines Est-ce une bonne chose d'utiliser les mêmes algorithmes pour toutes les composantes du système ? Pourquoi ? Peut-on faire en sorte d'utiliser les mêmes algorithmes tout en faisant en sorte d'avoir un cloisonnement entre le service (les communications entre UT) et la gestion de la constellation ?

Correction : L'avantage d'utiliser les même algorithmes c'est qu'on réduit les coûts de développement (logiciel, matériel, intégration et validation). L'inconvénient c'est qu'une vulnérabilité au niveau des UT d'un système public pourrait être rendue publique et aussi se retrouver ailleurs, par exemple dans les satellites.

On peut alors envisager d'utiliser des algorithmes différents pour sécuriser le lien SAT-CC et les liens entre UC. Un autre moyen qui assure une relative sécurité sans coûter plus cher est la **séparation de domaines**, c'est à dire utiliser les mêmes fonctions mais avec des paramètres différents.

Par exemple au lieu d'utiliser deux fonctions de hachage différentes on pourrait calculer $H(m||0x01)$ dans un cas $H(m||0x02)$ dans l'autre. Ou bien utiliser ECDH/ECDSA mais avec des courbes différentes, etc.

Question 22 : crypto-agilité Admettons que l'on doive modifier certains algorithmes cryptographiques sans interrompre le service. Comment feriez-vous ? Si on souhaite le faire par une mise à jour à distance, comment sécuriseriez-vous cette fonctionnalité ?

Correction : Etape 1 : s'assurer que les algorithmes en question puissent être supportés, en particulier par les UT et les satellites qui ne sont pas modifiables (pour des raisons évidentes pour les satellites, pour des raisons de coûts au niveau des UT)

Etape 2 : diffuser une mise à jour en amont avec un temps précis pour la transition (e.g. dans une semaine) afin que tous les terminaux aient le temps de changer d'algorithme. Cette mise à jour devra bien sûr être sécurisée.

Remarque : pour les UT on peut mettre à jour par action physique mais ce n'est pas conseillé pour des raisons de coût (cf injection de clés)

Pour sécuriser la mise à jour, il faut a minima l'authentifier, par exemple en la signant. La mise à jour pourrait être signée par le CC et diffusée par lui à toutes les composantes.